



Lab 04

Quét lỗ hổng bảo mật với Nessus

Vulnerability Scanning with Nessus

Môn học: **An toàn mạng máy tính**

GVTH: **KS.Nguyễn Ngọc Trưởng**

1 Giới thiệu chung

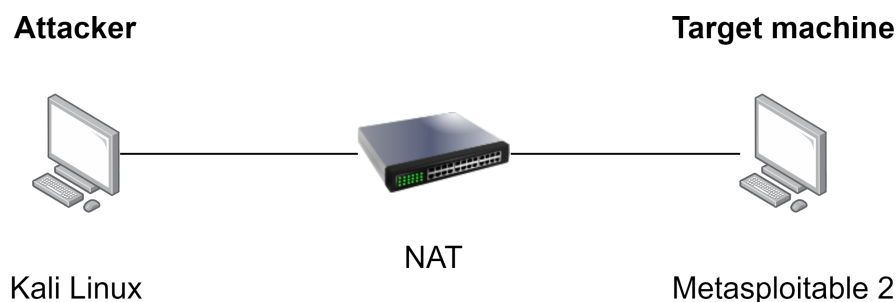
1.1 Mục tiêu

Hiểu và sử dụng các công cụ quét lỗ hổng tự động như Nessus, OpenVAS và Nmap.

1.2 Kiến thức nền tảng

Phát hiện lỗ hổng bảo mật là một phần không thể thiếu trong quá trình đánh giá bảo mật. Mặc dù chúng ta thích các tác vụ thủ công, chuyên biệt, tận dụng kiến thức và kinh nghiệm của chúng tôi trong quá trình kiểm tra bảo mật, nhưng các công cụ quét lỗ hổng bảo mật tự động vẫn có giá trị khi được sử dụng trong ngữ cảnh thích hợp. Trong bài thực hành này, sinh viên sẽ có cái nhìn tổng quan về quét lỗ hổng bảo mật tự động, thảo luận về các cân nhắc khác nhau của nó và tập trung vào cả Nessus và OpenVAS như những công cụ không thể thiếu.

1.3 Môi trường thực hành



Hình 1: Mô hình mạng bài thực hành

Bài thực hành này sẽ sử dụng 2 máy ảo:

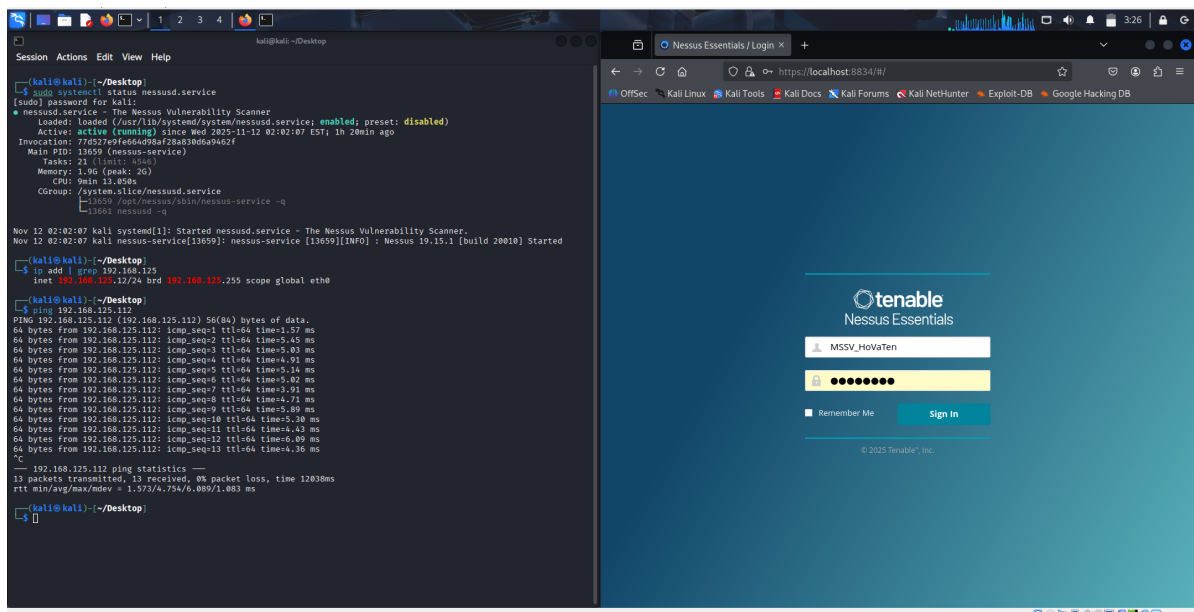
- Máy ảo Linux:
 - [Kali Linux](#)
 - [Ubuntu OS](#)
- Metasploitable 2:
 - <https://www.youtube.com/watch?v=l8v65ePR44k>
 - <https://www.geeksforgeeks.org/linux-unix/how-to-install-metasploitable-2-in-virtualbox/>
 - <https://sourceforge.net/projects/metasploitable/files/Metasploitable2/>

- Yêu cầu mô hình mạng:
 - Network address: 192.168.125.0/24
 - Máy ảo Linux: (192.168.125.1YY)
 - Metasploitable 2: (192.168.125.XXX)
 - * XXX là 3 số sau cùng của mã lớp.
 - Ví dụ lớp .Q11.2 thì XXX = 112, lớp .Q13.1 thì XXX = 131.
 - * YY là 2 chữ số của mã nhóm.
 - Ví dụ nhóm 1 thì YY = 01, Địa chỉ IP của máy Linux là 192.168.125.101

Xem thêm tại **PHỤ LỤC CÀI ĐẶT**.

1.4 Kiểm tra môi trường trước khi thực hành

1. Tại máy Kali Linux, sinh viên thực hiện kiểm tra địa chỉ IP, đường kết nối của máy Kali Linux đến máy Metasploitable2, và đường kết nối của máy Kali Linux đến Internet.
2. Tại máy Metasploitable2, sinh viên thực hiện kiểm tra địa chỉ IP.
3. Sinh viên truy cập Nessus, sau khi đã cài đặt thành công thông đường dẫn <https://localhost:8834/> hoặc <https://192.168.125.1YY:8834/>



Hình 2: Kiểm tra môi trường trước khi thực hành

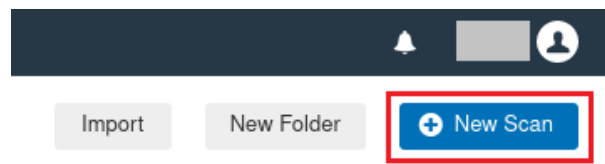
2 Nội dung thực hành

2.1 Quét lỗ hổng sử dụng công cụ Nessus

Nessus là một công cụ quét lỗ hổng phổ biến, hỗ trợ hơn 130000 plugin. Ban đầu, Nessus được phát triển như một ứng dụng mã nguồn mở, tuy nhiên, năm 2005, mã nguồn đã được đóng. Sự thay đổi đối với mô hình nguồn đóng dẫn đến các nhánh của dự án mã nguồn mở được phát triển, và một trong số đó là OpenVAS.

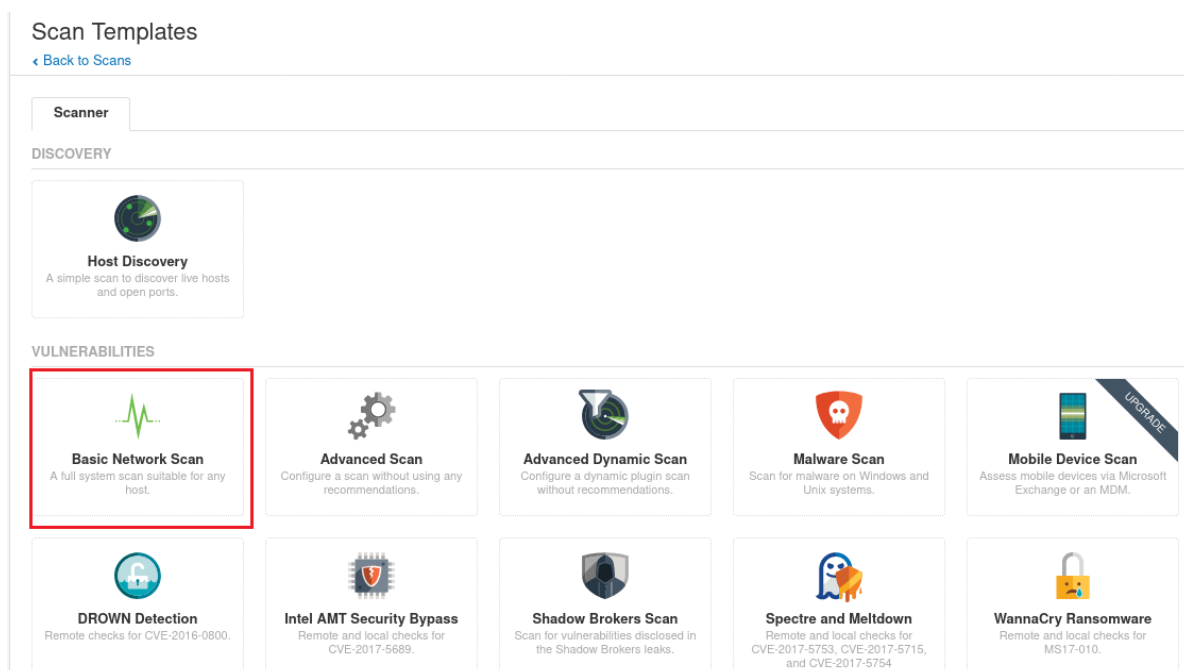
2.1.1 Khai báo đối tượng

Sau khi Nessus được cài đặt thành công, thực hiện scan lần đầu tiên. Để bắt đầu, chúng ta bấm vào nút New Scan



Hình 3: Tiến hành tạo một lần scan mới

Nessus hỗ trợ nhiều loại quét lỗ hổng khác nhau. Tuy nhiên, trong nội dung bài thực hành này, chúng ta sẽ tập trung vào Basic Network Scan



Hình 4: Chọn Basic Network Scan

Nessus sẽ hiển thị màn hình cài đặt cấu hình scan với 2 tham số được yêu cầu khai báo: tên và danh sách các mục tiêu cần scan. Nessus hỗ trợ khai báo mục tiêu sử dụng địa

chỉ IP, dãy địa chỉ IP; danh sách FQDN hoặc IP được cách nhau bằng dấu “,”. Ví dụ, trong bài thực hành này, chúng ta sẽ thực hiện quét máy Metasploitable2, có địa chỉ IP là 192.168.125.XXX. Chúng ta sẽ nhập “Metasploitable2 – Basic” trong trường Name và địa chỉ IP trong trường Targets:

New Scan / Basic Network Scan

[Back to Scan Templates](#)

Settings

Credentials

Plugins

BASIC

General

Schedule

Notifications

DISCOVERY

ASSESSMENT

REPORT

ADVANCED

Name

Description

Folder

Targets

Metasploitable2 – Basic

My Scans

192.168.125.112

Hình 5: Cấu hình scan máy Metasploitable2

2.1.2 Cấu hình các định nghĩa quét (Scan Definitions)

Trong mục tiêu bài thực hành này, chúng ta đã chọn template Basic Network Scan, các thuộc tính sẽ được thiết lập mặc định. Tuy nhiên, trong thực tế, chúng ta cần xem xét đến các yếu tố khác như môi trường quét, thời gian, mục tiêu sẽ được quét,... Một số điều cần xem xét khi sử dụng template Basic Network Scan bao gồm:

- Mục tiêu quét nằm trong mạng nội bộ hay có thể truy cập từ bên ngoài Internet?
- Chúng ta có được phép tấn công brute force thông tin đăng nhập không?
- Scan tất cả TCP và UDP port hay chỉ một số port thông dụng?
- Các kiểm tra nào mà scanner có thể chạy, và kiểm tra nào không thể chạy?
- Scanner chạy quét có thông tin đăng nhập hay không có thông tin đăng nhập?

Mặc định, template Basic Network Scan chỉ thực hiện quét các port thông dụng. Tuy nhiên, bây giờ chúng ta cần thực hiện quét tất cả các port. Để thay đổi, click vào Discovery phía bên trái của thẻ Settings

New Scan / Basic Network Scan

[Back to Scan Templates](#)

Settings | **Credentials** | **Plugins**

BASIC

- General
- Schedule**
- Notifications
- DISCOVERY**
- ASSESSMENT
- REPORT
- ADVANCED

Name: Metasploitable2 – Basic

Description:

Folder: My Scans

Targets: 192.168.125.112

Upload Targets [Add File](#)

Hình 6: Truy cập thiết lập Discovery Trong mục Scan Type, thay đổi giá trị từ Port scan (common ports) thành Custom

Settings | **Credentials** | **Plugins**

BASIC

- DISCOVERY**
- ASSESSMENT
- REPORT
- ADVANCED

Scan Type:

Use fast network discovery

Port Scanner Settings:

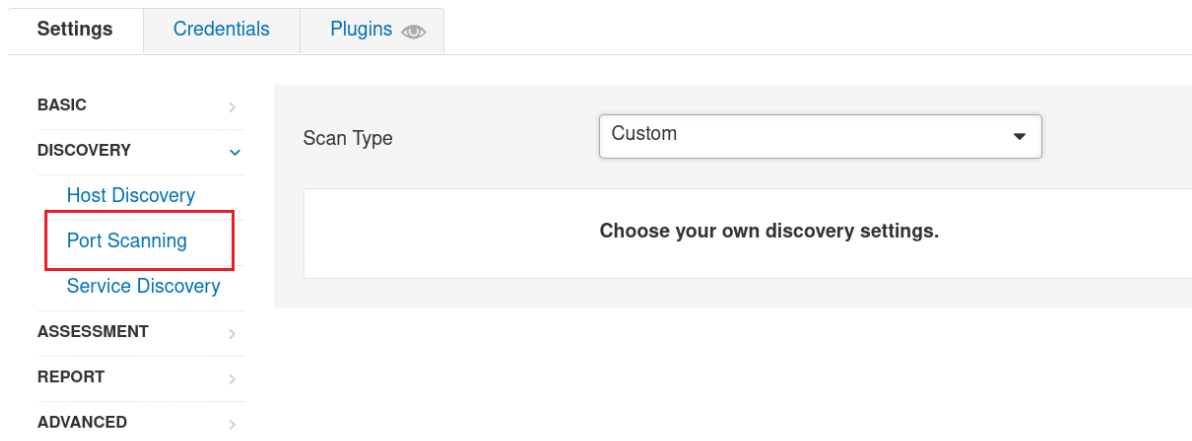
- Scan common ports
- Use netstat if credentials are provided
- Use SYN scanner if necessary

Ping hosts using:

- TCP
- ARP
- ICMP (2 retries)

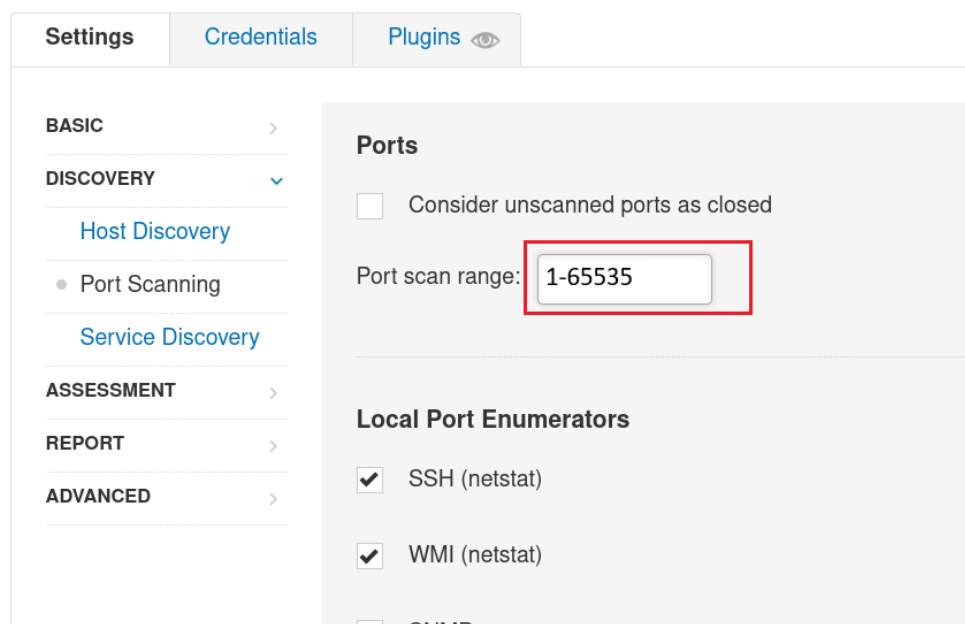
Hình 7: Cấu hình Scanner sử dụng loại Custom Port

Bên trái, chọn Port Scanning ở trong mục con của Discovery để cấu hình dãy port muốn scan.



Hình 8: Chọn tùy chọn Port Scanning

Trong mục Port Scanning, chúng ta sẽ thiết lập dãy port muốn scan ở trong phần Port scan range. Nhập giá trị “1-65535” để thực hiện quét tất cả các port.



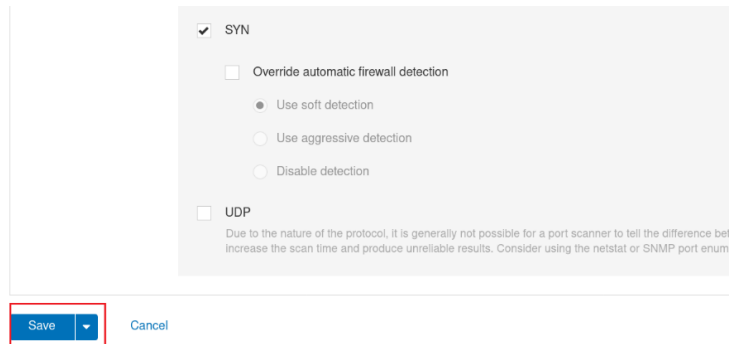
Hình 9: Cấu hình Scanner để quét tất cả các port

Trong kịch bản này, chúng ta đã chọn định nghĩa scan chỉ quét các port TCP, không quét UDP. Điều này sẽ tăng tốc độ quét, nhưng sẽ bỏ qua các dịch vụ UDP quan trọng trên máy mục tiêu. Trong quá trình quét, chúng ta phải cân nhắc tính ổn định của mạng mục tiêu, phạm vi mục tiêu, thời lượng tương tác và nhiều yếu tố khác khi định cấu hình tùy chọn quét cổng. Ngoài ra, chúng ta đã không cấu hình bất kỳ thông tin đăng nhập nào, điều đó đồng nghĩa với việc quét mà không cần tài khoản đăng nhập. Thêm vào đó, chúng ta chấp nhận mặc định trong Basic Network Scan, có nghĩa là brute force tài khoản đăng nhập sẽ không được kích hoạt. Bây giờ, chúng ta đã xem xét hoàn tất tất cả các tùy chọn

cấu hình và hiểu (ít nhất là ở cấp độ cao) scanner sẽ làm gì, chúng ta có thể tiến hành chạy quét lần đầu tiên.

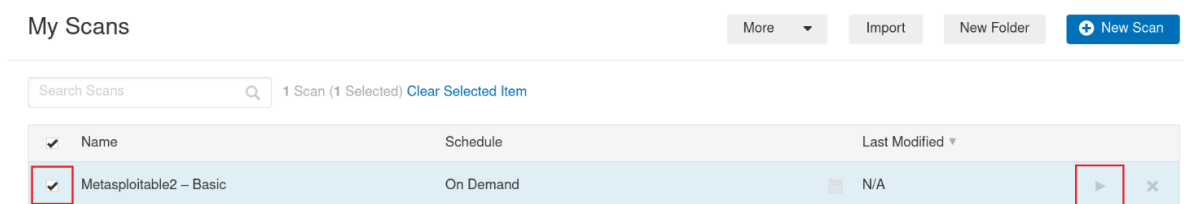
2.1.3 Quét lỗ hổng không sử dụng tài khoản chứng thực

Sau khi thiết lập mọi tham số, kéo xuống dưới và chọn Save



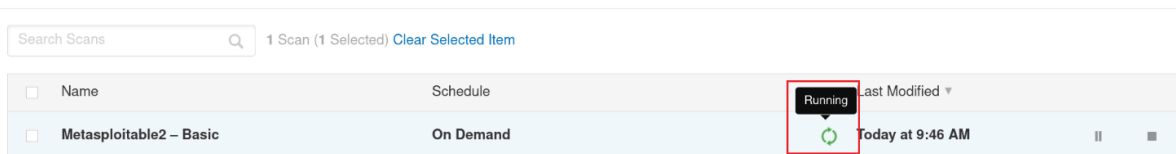
Hình 10: Chọn save để lưu lại các cài đặt

Sau khi save, quay về mục My Scans, chọn vào template “Metasploitable2 – Basic”, sau đó chọn Launch



Hình 11: Tiến hành chạy quét lần đầu tiên

Trạng thái hiện tại được cập nhật thành Running.



Hình 12: Chờ quá trình scan hoàn tất

Sau khi quét hoàn tất, trạng thái sẽ chuyển sang Completed (Hình 26)

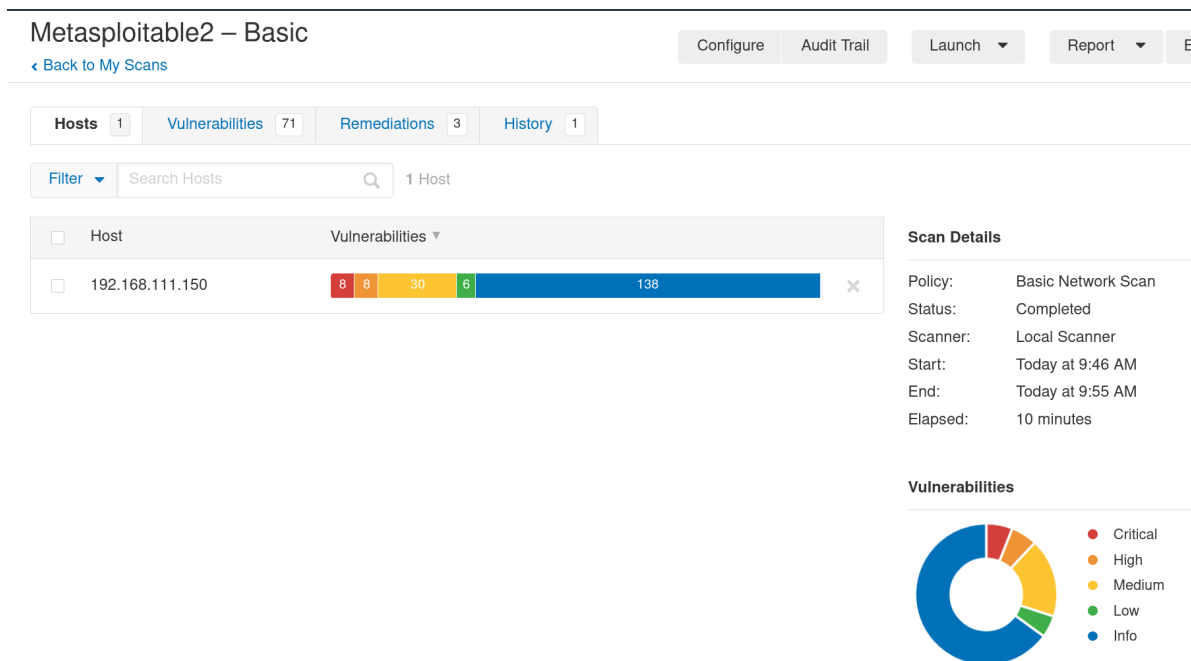
Search Scans

1 Scan

☐	Name	Schedule	Completed	Last Modified
☐	Metasploitable2 – Basic	On Demand	☒	Today at 9:55 AM

Hình 13: Quá trình scan hoàn tất

Sau khi scan hoàn tất, click vào tên scan, “Metasploitable2 – Basic” để hiển thị danh sách các host được khám phá trong quá trình scan và tóm tắt các lỗ hổng tồn tại.



Hình 14: Giao diện tổng quan

Cho dù chúng ta quét một hay nhiều máy chủ, chúng ta có thể nhấp vào địa chỉ IP hoặc tên máy chủ để hiển thị các lỗ hổng được phát hiện đối với mục tiêu đó, như thể hiện trong Hình 13

The screenshot shows the Nessus interface for a Metasploitable2 host. The main table lists 71 vulnerabilities, with the first few being Critical. The host details on the right show the IP, MAC, OS, and a donut chart for vulnerability severity distribution.

Sev	Name	Family	Count
CRITICAL	SSL (Multiple Issues)	Gain a shell remotely	3
CRITICAL	Bind Shell Backdoor Det...	Backdoors	1
CRITICAL	NFS Exported Share Inf...	RPC	1
CRITICAL	rexecd Service Detection	Service detection	1
CRITICAL	Unix Operating System ...	General	1
CRITICAL	VNC Server 'password' ...	Gain a shell remotely	1
MIXED	DNS (Multiple Issues)	DNS	6
MIXED	ISC Bind (Multiple I...	DNS	5

Host Details

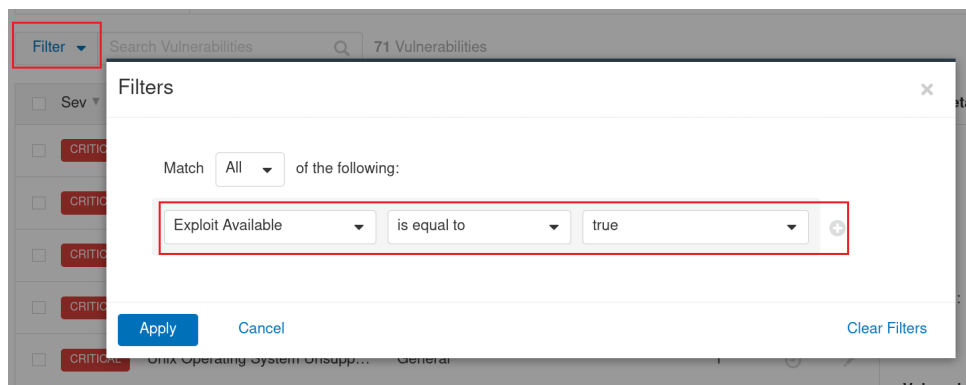
IP: 192.168.125.112
MAC: 00:0C:29:FA:DD:2A
OS: Linux Kernel 2.6 on Ubuntu 8.04 (hardy)
Start: Today at 9:46 AM
End: Today at 9:55 AM
Elapsed: 10 minutes
KB: [Download](#)

Vulnerabilities

Donut chart showing severity distribution: Critical (red), High (orange), Medium (yellow), Low (green), Info (blue).

Hình 15: Xem các lỗ hổng đã được phát hiện

Chúng ta có thể thực hiện lọc các lỗ hổng theo mức độ ảnh hưởng, CVE, khả năng khai thác, và nhiều hơn thế nữa. Để hiển thị các lỗ hổng có thể dẫn đến kiểm soát máy chủ mục tiêu, chúng ta có thể click Filter và thay đổi giá trị lọc thành “Exploit Available”, giữ nguyên các giá trị mặc định của “is equal to” và “true”. Sau khi cấu hình xong, click vào Apply



Hình 16: Lọc các lỗ hổng với các lỗi khai thác

Kết quả lọc sẽ chỉ hiển thị các lỗ hổng theo nhóm được định nghĩa bởi Nessus

Vulnerabilities 8

1 Filter Search Vulnerabilities 8 Vulnerabilities

☐	Sev ▾	Name ▲	Family ▲	Count ▾		
☐	CRITICAL	2 SSL (Multiple Issues)	Gain a shell remotely	3	🕒	✎
☐	CRITICAL	NFS Exported Share Informatio...	RPC	1	🕒	✎
☐	HIGH	Apache Tomcat AJP Connector ...	Web Servers	1	🕒	✎
☐	HIGH	ISC BIND Denial of Service	DNS	1	🕒	✎
☐	HIGH	Multiple Vendor DNS Query ID ...	DNS	1	🕒	✎
☐	HIGH	rlogin Service Detection	Service detection	1	🕒	✎
☐	HIGH	rsh Service Detection	Service detection	1	🕒	✎
☐	MEDIUM	SMTP Service STARTTLS Plain...	SMTP problems	1	🕒	✎

Hình 17: Danh sách lỗ hổng được phân loại theo nhóm

Trong khi việc gom nhóm có thể hữu ích, chúng ta sẽ click vào biểu tượng hình bánh răng bên góc phải của bảng và chọn Disable Groups.

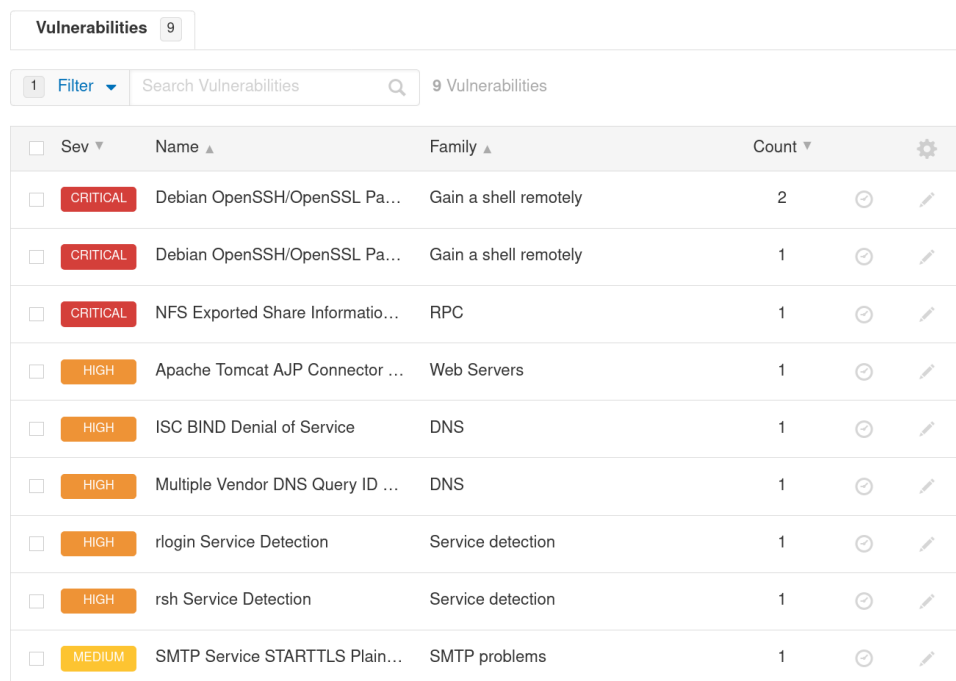
☐	Sev ▾	Name ▲	Family ▲	Count ▾			
☐	CRITICAL	2 SSL (Multiple Issues)	Gain a shell remotely	3		⚙️	H
☐	CRITICAL	NFS Exported Share Informatio...	RPC	1			

Disable Groups

Show Snoozed

Hình 18: Vô hiệu hóa tính năng gom nhóm

Kết quả sẽ hiển thị danh sách tất cả lỗ hổng trên 1 trang, được sắp xếp theo mức độ ảnh hưởng.



Vulnerabilities 9				
1	Filter	Search Vulnerabilities	9 Vulnerabilities	
☐	Sev	Name	Family	Count
☐	CRITICAL	Debian OpenSSH/OpenSSL Pa...	Gain a shell remotely	2
☐	CRITICAL	Debian OpenSSH/OpenSSL Pa...	Gain a shell remotely	1
☐	CRITICAL	NFS Exported Share Informatio...	RPC	1
☐	HIGH	Apache Tomcat AJP Connector ...	Web Servers	1
☐	HIGH	ISC BIND Denial of Service	DNS	1
☐	HIGH	Multiple Vendor DNS Query ID ...	DNS	1
☐	HIGH	rlogin Service Detection	Service detection	1
☐	HIGH	rsh Service Detection	Service detection	1
☐	MEDIUM	SMTP Service STARTTLS Plain...	SMTP problems	1

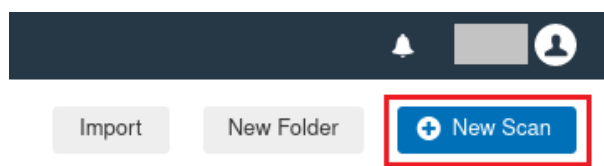
Hình 19: Hiển thị kết quả không sử dụng chế độ gom nhóm

Nhiệm vụ 2.1

1. Thực hiện lại các bước trên để quét máy Metasploitable 2 không sử dụng tài khoản chứng thực.
2. Bật Wireshark sau đó tiến hành quét và xác định các bước mà Nessus đã thực hiện để hoàn tất quá trình quét.
3. Quét lại nhưng quét thêm port UDP.

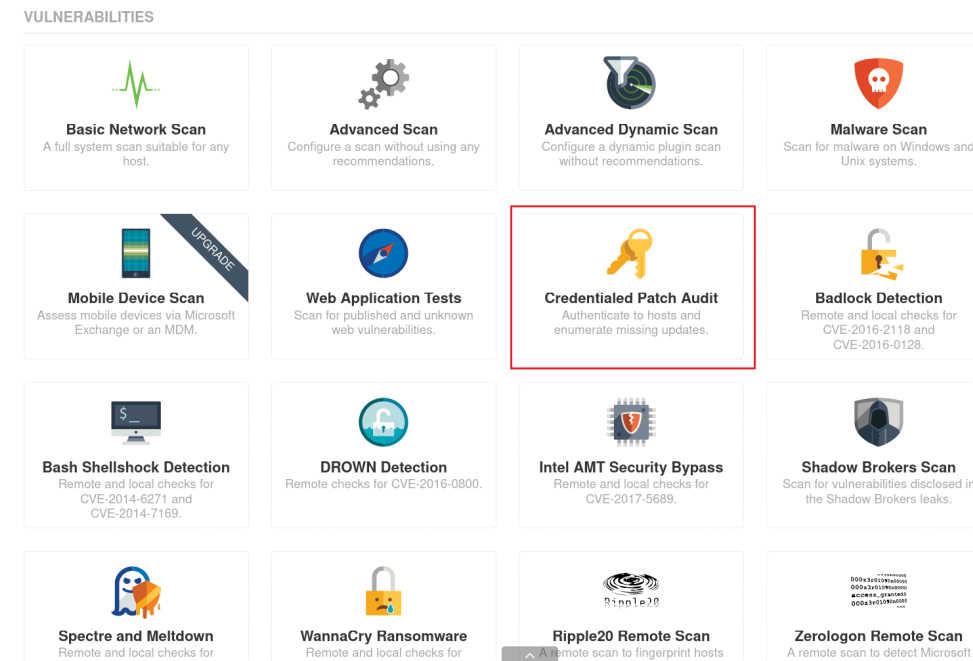
2.1.4 Quét lỗ hổng sử dụng tài khoản chứng thực

Chúng ta có thể có được nhiều thông tin chi tiết hơn và giảm thiểu các false positive bằng cách thực hiện scan sử dụng tài khoản chứng thực của máy mục tiêu. Tuy nhiên, lưu ý rằng với tư cách là những pentester, chúng ta sẽ không thực hiện scan có tài khoản chứng thực trong hầu hết các trường hợp nếu không có sự cho phép rõ ràng của quản trị viên của mạng mục tiêu do có nguy cơ làm gián đoạn (không chủ ý) tới hệ thống của mục tiêu. Để bắt đầu, chúng ta sẽ chọn nút New Scan



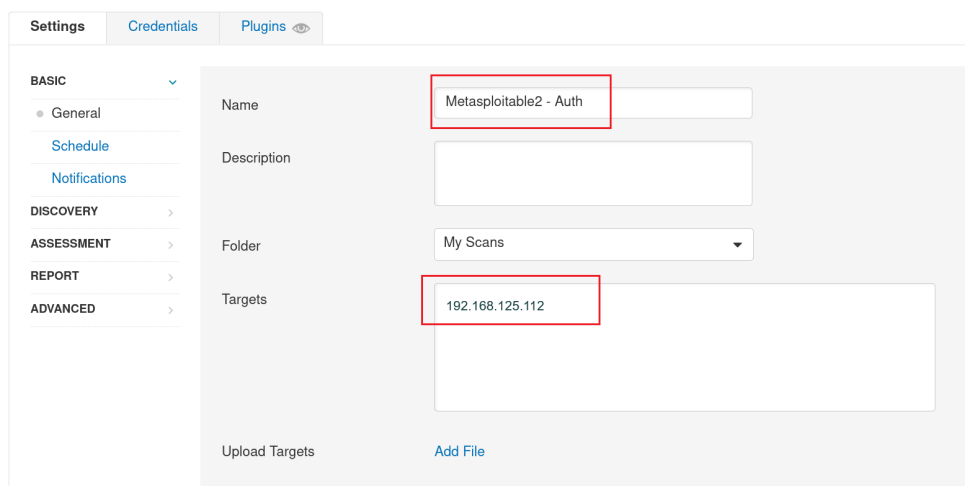
Hình 20: Khởi tạo 1 lần scan mới

Mặc dù tất cả template của Nessus đều chấp nhận thông tin đăng nhập của người dùng, chúng ta sẽ sử dụng template Credentialed Patch Audit, được cấu hình sẵn để thực hiện kiểm tra bảo mật cục bộ đối với máy mục tiêu. Template này không chỉ quét các bản vá lỗi còn thiếu ở mức độ hệ điều hành mà còn quét các ứng dụng lỗi thời có thể dễ bị tấn công như leo thang đặc quyền.



Hình 21: Chọn template “Credentialed Patch Audit”

Tương tự như Basic Network Scan, chúng ta cần cung cấp tên và mục tiêu cần quét.



Hình 22: Cấu hình cơ bản của Authenticated Scan

Tiếp theo, chọn thẻ Credentials và chọn loại SSH. Trong mục Authentication method, chọn password, thiết lập username là “msfadmin” và password là “msfadmin”.

Lab 04: Quét lỗ hổng bảo mật với Nessus

Settings **Credentials** Plugins

1

CATEGORIES Host

Filter Credentials

SNMPv3 1

SSH 2

Windows

SSH

Authentication method password 3

Username msfadmin

Password (unsafe)

Elevate privileges with Nothing

Custom password prompt password:

Hình 23: Nhập thông tin tài khoản SSH

Cuối cùng, thực hiện quét máy mục tiêu bằng cách chọn Launch

Save Launch Cancel

Hình 24: Thực hiện scan mục tiêu có sử dụng tài khoản chứng thực

Sau khi scan chuyển sang trạng thái “Completed”, chúng ta có thể click vào tên scan và mở danh sách các host và click vào địa chỉ IP của máy metasploitable 2, kết quả sẽ hiển thị danh sách các lỗ hổng được khám phá có thể được khai thác trên máy chủ.

Metasploitable2 - Auth / 192.168.125.112

Configure Audit Trail Launch Report Export

Vulnerabilities 245

Filter Search Vulnerabilities 245 Vulnerabilities

Sev	Name	Family	Count	
CRITICAL	Ubuntu 6.06 LTS / 7.04 / 7.10 / 8.04 LTS : gnutils12, gnutils13 vul...	Ubuntu Local Security Checks	1	
CRITICAL	Ubuntu 6.06 LTS / 7.04 / 7.10 / 8.04 LTS : libxml2 vulnerabilities (...)	Ubuntu Local Security Checks	1	
CRITICAL	Ubuntu 6.06 LTS / 7.04 / 7.10 / 8.04 LTS : linux, linux-source-2.6...	Ubuntu Local Security Checks	1	
CRITICAL	Ubuntu 6.06 LTS / 7.10 / 8.04 LTS / 8.10 : libxml2 vulnerabilities (...)	Ubuntu Local Security Checks	1	
CRITICAL	Ubuntu 6.06 LTS / 7.10 / 8.04 LTS : linux-source-2.6.15/22, linux ...	Ubuntu Local Security Checks	1	
CRITICAL	Ubuntu 6.06 LTS / 8.04 LTS / 8.10 / 9.04 / 9.10 : linux, linux-sour...	Ubuntu Local Security Checks	1	
CRITICAL	Ubuntu 6.06 LTS / 8.04 LTS / 8.10 / 9.04 : dhcp3 vulnerability (U...	Ubuntu Local Security Checks	1	
CRITICAL	Ubuntu 6.06 LTS / 8.04 LTS / 8.10 / 9.04 : libxml2 vulnerabilities (...)	Ubuntu Local Security Checks	1	
CRITICAL	Ubuntu 6.06 LTS / 8.04 LTS / 8.10 : apt vulnerabilities (USN-762-1)	Ubuntu Local Security Checks	1	

Host Details

IP: 192.168.125.112

OS: Linux Kernel 2.6.24-16-server on Ubuntu 8.04

Start: Today at 11:02 AM

End: Today at 11:05 AM

Elapsed: 3 minutes

KB: Download

Vulnerabilities

Donut chart showing vulnerability distribution: Critical (red), High (orange), Medium (yellow), Low (green), Info (blue).

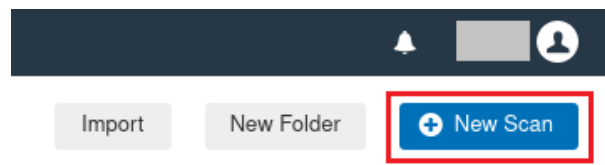
Hình 25: Danh sách các lỗ hổng khi quét có tài khoản chứng thực

Nhiệm vụ 2.2

1. Thực hiện lại các bước trên để quét máy Metasploitable 2 có sử dụng tài khoản chứng thực.
2. Kiểm tra kết quả quét và so sánh với việc quét không sử dụng tài khoản chứng thực.
3. Hãy liệt kê các ưu, nhược điểm khi quét có tài khoản chứng thực và không có tài khoản chứng thực.

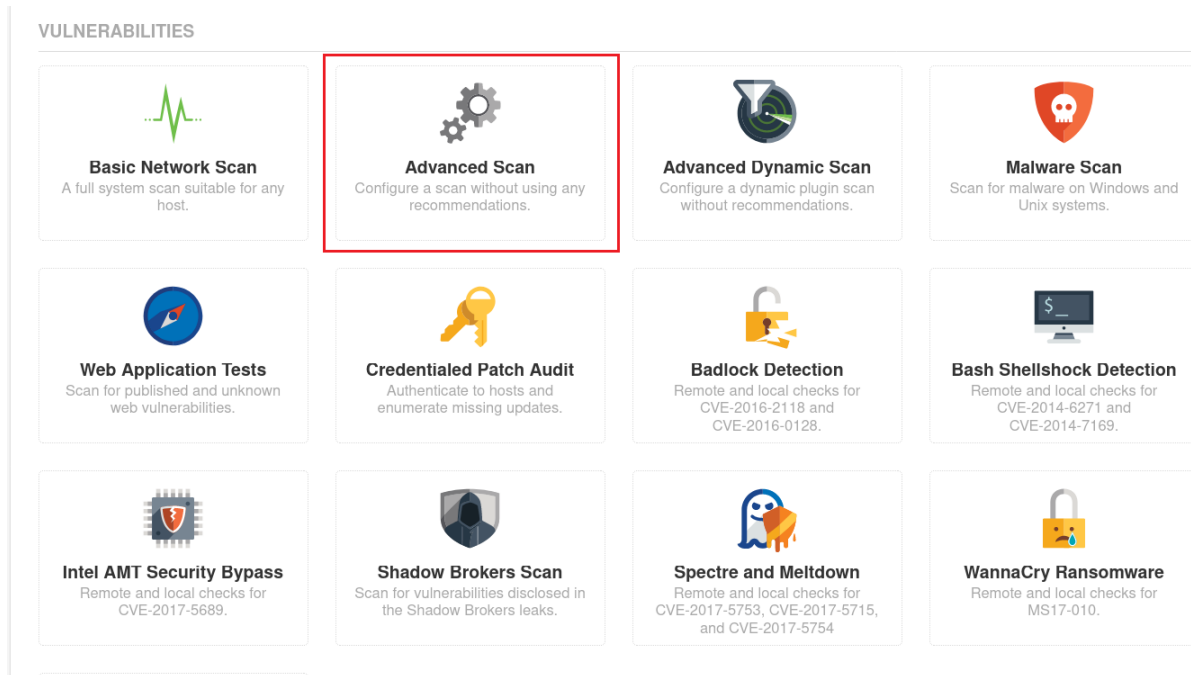
2.1.5 Quét với Plugin được chỉ định

Mặc định, Nessus sẽ kích hoạt số lượng các plugin khi chạy các template mặc định. Mặc dù điều này có thể có ích trong nhiều trường hợp, những chúng ta có thể tinh chỉnh các tùy chọn của mình, ví dụ, chạy một plugin nào đó nhanh chóng. Chúng ta có thể sử dụng tính năng này để kiểm chứng các phát hiện trước đó hoặc nhanh chóng phát hiện ra tất cả các mục tiêu dễ bị khai thác bởi một lỗ hổng trong cùng một môi trường. Trong trường hợp này, chúng ta sẽ chạy plugin NFS Exported Share Information Disclosure. Để chạy scan cho một plugin, chúng ta lại bắt đầu bằng New Scan



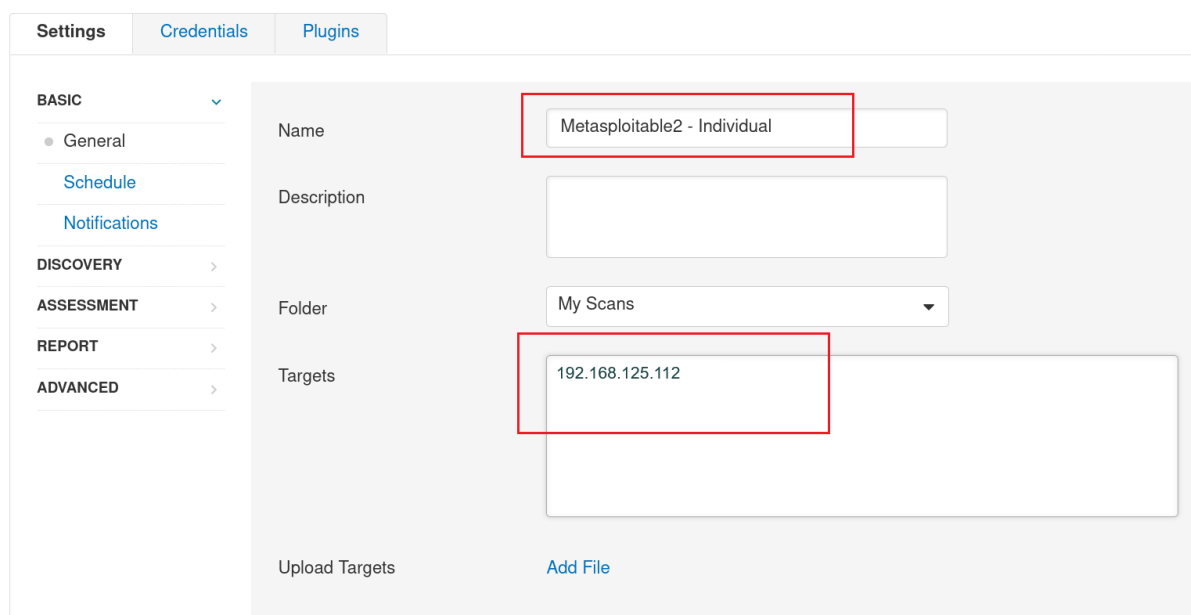
Hình 26: Khởi tạo scan mới

Lần này, chúng ta sẽ sử dụng template Advanced Scan. Không giống với các template Basic Network Scan và Credentialed Patch Audit đã được sử dụng trước đó, template Advanced Scan không sử dụng các đề xuất cho các cấu hình quét. Tuy nhiên, template này cung cấp một bộ các giá trị mặc định “Nâng cao” thường bị ẩn hoặc không khả dụng đối với các template khác. Lưu ý rằng Advanced Scan cho phép chúng ta chọn các plugin riêng lẻ, một tùy chọn không có sẵn cho hầu hết các template khác.



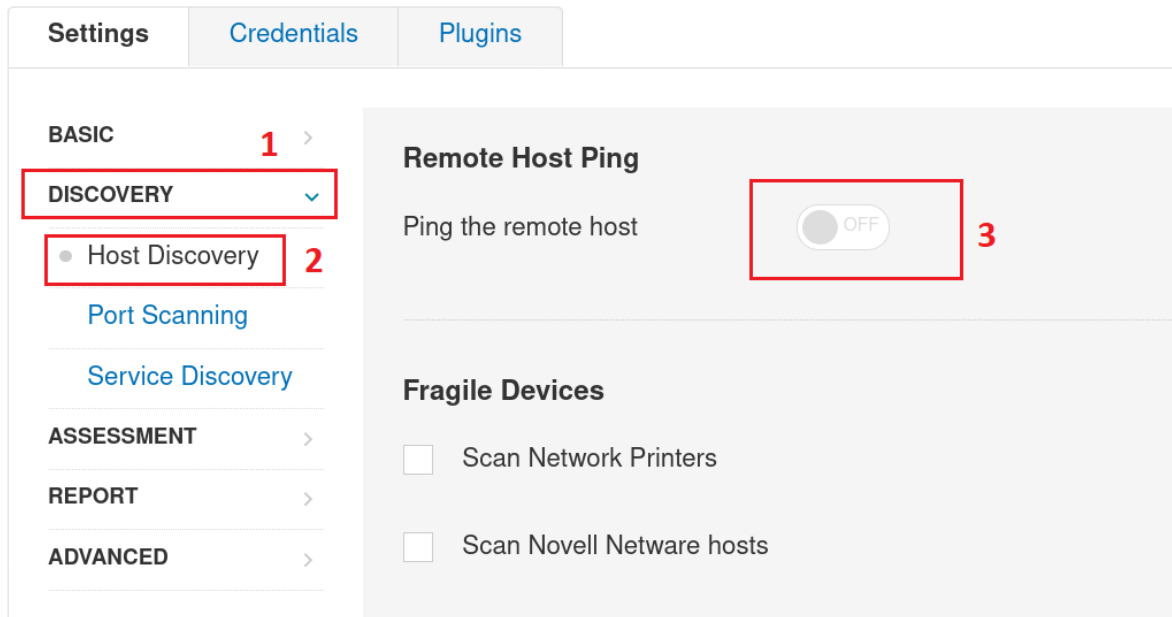
Hình 27: Chọn template “Advanced Scan”

Tương tự, cũng đặt tên và đối tượng cần scan.



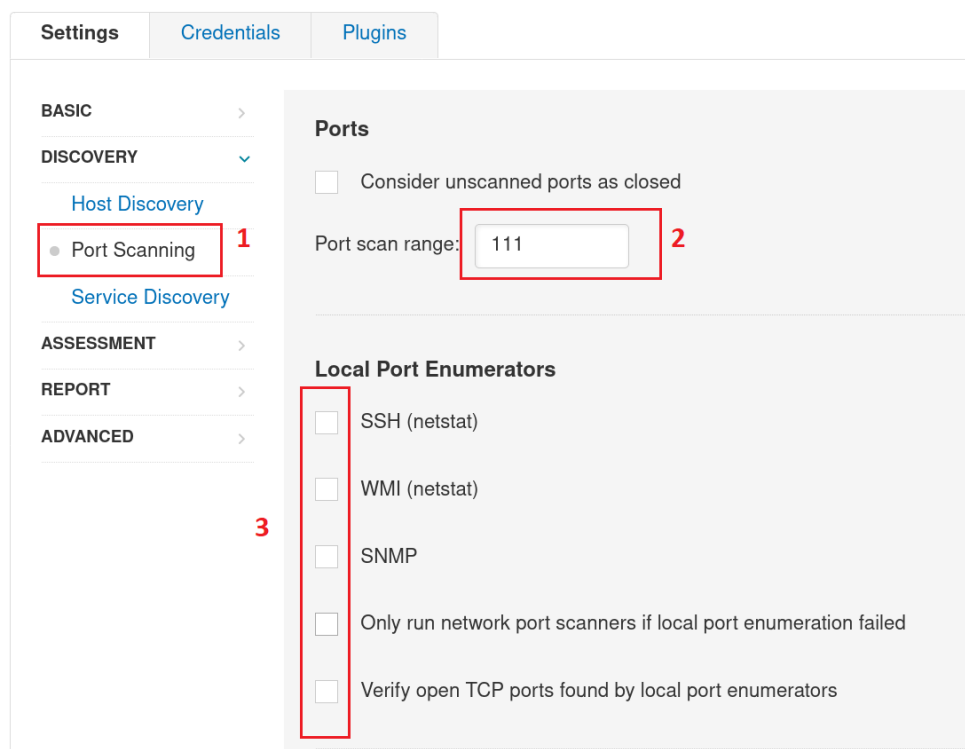
Hình 28: Thiết lập tên và đối tượng cần quét

Để tiết kiệm thời gian và ít để lại dấu vết, chúng ta sẽ tắt Host discovery, vì chúng ta biết được host vẫn còn hoạt động.



Hình 29: Tắt tính năng Host Discovery

Vì chúng ta chỉ scan dịch vụ RPC và biết rằng RPC chạy trên TCP port 111, nên chúng ta chỉ scan duy nhất port này.



Hình 30: Tắt hết các port không cần thiết

Sau khi giảm thiểu tối đa các tùy chọn scan, bây giờ tiến hành chọn plugin. Chọn thẻ Plugins và click vào Disable All ở góc phải

New Scan / Advanced Scan

[Back to Scan Templates](#)

2

[Disable All](#)[Enable All](#)

Settings

Credentials

Plugins

Show Enabled | Show All

STATUS	PLUGIN FAMILY ▲	TOTAL
DISABLED	AIX Local Security Checks	11377
DISABLED	Amazon Linux Local Security Checks	1718
DISABLED	Backdoors	121
DISABLED	Brute force attacks	26
DISABLED	CentOS Local Security Checks	3103
DISABLED	CGI abuses	4382
DISABLED	CGI abuses : XSS	687
DISABLED	CISCO	1647
DISABLED	Databases	701
DISABLED	Debian Local Security Checks	7096

STATUS	PLUGIN NAME	PLUGIN ID
	No plugin family selected.	

Hình 31: Tắt hết tất cả các plugin

Để tiến hành quét NFS shares, chúng ta sẽ di chuyển đến “RPC” bên cột bên trái và thiết lập “NFS Exported Share Information Disclosure” ở cột bên phải thành Enabled

Settings

Credentials

Plugins

DISABLED

Policy Compliance

13

DISABLED

Red Hat Local Security Checks

6977

MIXED

RPC

38

DISABLED

SCADA

3

DISABLED

Scientific Linux Local Security Checks

3016

DISABLED

Service detection

496

DISABLED

Settings

103

DISABLED

Slackware Local Security Checks

1219

DISABLED

SMTP problems

148

DISABLED

SNMP

33

DISABLED

Solaris Local Security Checks

3726

DISABLED

Multiple Vendor RPC portmapper Access Restriction ...

54586

DISABLED

Multiple Vendor rpc.nisd Long NIS+ Argument Remot...

10251

ENABLED

NFS Exported Share Information Disclosure

11356

DISABLED

NFS portmapper localhost Mount Request Restricted...

11358

DISABLED

NFS Predictable Filehandles Filesystem Access

11353

DISABLED

NFS Server Superfluous

42255

DISABLED

NFS Share Export List

10437

DISABLED

NFS Share User Mountable

15984

DISABLED

NFS Shares World Readable

42256

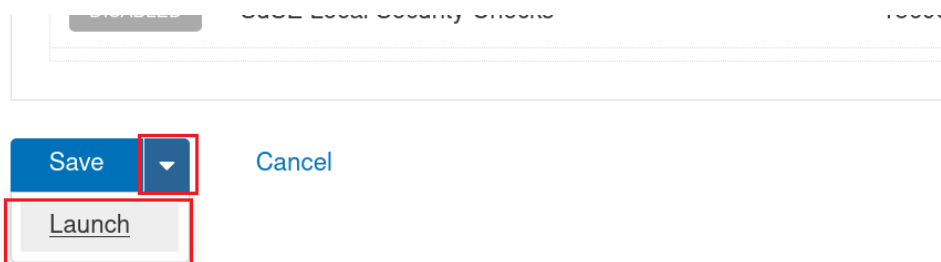
DISABLED

NIS passwd.byname Map Disclosure

12238

Hình 32: Bật plugin NFS

Bây giờ ta đã cấu hình xong, tiến hành quét. Click vào Launch.



Hình 33: Tiến hành quét NFS

Sau khi trạng thái quét chuyển sang “Completed”, chúng ta có thể click vào tên scan, sau đó địa chỉ IP máy mục tiêu. Di chuyển đến lỗ hổng Critical duy nhất và click vào để hiển thị chi tiết thông tin lỗ hổng.

CRITICAL NFS Exported Share Information Disclosure >

Description

At least one of the NFS shares exported by the remote server could be mounted by the scanning host. An attacker may be able to leverage this to read (and possibly write) files on remote host.

Solution

Configure NFS on the remote host so that only authorized hosts can mount its remote shares.

Output

```
The following NFS shares could be mounted :  
  
+ /  
+ Contents of / :  
- .  
- ..  
- bin  
- boot  
- cdrom  
- dev  
more...
```

Port ▲	Hosts
2049 / udp / rpc-nfs	192.168.125.112

Hình 34: Xem kết quả scan với chỉ 1 plugin duy nhất

Nhiệm vụ 2.3

1. Thực hiện lại các bước trên để quét máy Metasploitable 2 sử dụng plugin NFS Exported Share Information Disclosure.
2. Chạy Wireshark hoặc tcpdump trong suốt quá trình scan sử dụng 1 plugin duy nhất. Liệt kê các port khác mà Nessus thực hiện scan, mà không phải port 111? Tại sao Nessus lại scan các port khác, trong khi chúng ta đã chỉ định chỉ scan duy nhất 1 port là 111?
3. Mô tả cách làm để ngăn chặn việc Nessus scan port khác không phải là port được chỉ định?
4. Thực hiện quét lại sử dụng 2 plugin khác.

Nhiệm vụ 2.4

Sinh viên/nhóm sinh viên tìm hiểu 1 trong các công cụ quét lỗ hổng tự động sau đây, và viết báo cáo kết quả theo như các phần đã chia ở bài tập 1:

- OpenVAS (<https://www.openvas.org/>)
- Tsunami (<https://github.com/google/tsunami-security-scanner>)
- Rapid7 Nexpose (<https://www.rapid7.com/try/nexpose/>)
- Qualys Community Edition (<https://www.qualys.com/community-edition/>)
- Arachni (<https://www.arachni-scanner.com/>)
- Sn1per (<https://github.com/1N3/Sn1per>)
- Trivy (<https://github.com/aquasecurity/trivy>)
- Jok3r (<https://github.com/koutto/jok3r>)

3 Yêu cầu và đánh giá

Sinh viên được khuyến khích làm việc theo nhóm từ hai đến ba người.

▼ Thêm bài nộp

Nộp tập tin

Kích thước tối đa với một tập tin 10 MB, số lượng tập tin đính kèm tối đa:20

Tập tin				
☐	Tên	Sửa lần cuối	Kích thước	Loại
☐	 Lab01_Group02_Report.pdf	13/02/2026 11:05	95.2 KB	Tài liệu PDF
☐	 Lab01_Group02_Resource.zip	13/02/2026 11:06	49.7 KB	Lưu trữ (ZIP)

Hình 35: Yêu cầu bài nộp trên hệ thống UIT Courses

Yêu cầu chung

Bài nộp phải tuân thủ các quy định sau:

- **Bài nộp phải được nộp trên hệ thống UIT Courses** (như hình 35), bao gồm:
 1. Một tệp báo cáo thực hành ở định dạng `LabXGroupY_Report.pdf`, trình bày theo đúng mẫu quy định.
 2. Một tệp `LabXGroupYY_Resource.zip` (nếu có), bao gồm mã nguồn, dữ

liệu, chương trình thực thi và các tài nguyên liên quan phục vụ cho việc kiểm tra và đánh giá.

- **Báo cáo thực hành** cần đảm bảo những yêu cầu sau:

1. Báo cáo phải trình bày đầy đủ nội dung thực hiện, phương pháp, kết quả và các nhận xét cần thiết; nội dung phải rõ ràng, chính xác và có tính hệ thống và hình ảnh minh chứng cần thiết.
2. Báo cáo không chấp nhận việc sử dụng đồng thời nhiều ngôn ngữ trong cùng một báo cáo, trừ các thuật ngữ kỹ thuật hoặc từ khóa chuyên ngành (cả một câu, cả một đoạn văn).
3. Đối với các nhiệm vụ lập trình, báo cáo phải mô tả chi tiết các thành phần chính của chương trình, giải thích các bước thực hiện và minh họa kết quả chạy chương trình khi cần thiết. Việc chỉ nộp mã nguồn mà không có mô tả hoặc phân tích sẽ không được chấm điểm cho nhiệm vụ đó.
4. **Đối với các bài lab về hệ thống, báo cáo *bắt buộc* phải trình bày đầy đủ mô hình kiến trúc mạng (kèm sơ đồ nếu có), danh sách địa chỉ IP của từng máy, mô tả chi tiết quá trình thiết lập môi trường và các bước kiểm tra ban đầu trước khi thực hiện bài lab. *Nếu không có nội dung này, bài lab sẽ không được đánh giá và bị chấm 0 điểm.***
5. Bài nộp phải là kết quả làm việc của chính sinh viên hoặc nhóm sinh viên. Sinh viên được phép thảo luận để trao đổi ý tưởng, nhưng mọi hình thức sao chép toàn bộ hoặc một phần báo cáo đều bị xem là vi phạm quy định về liêm chính học thuật và không được đánh giá điểm cho bài thực hành. Mọi tài liệu tham khảo phải được trích dẫn đầy đủ.

- **Nhóm sinh viên phải sử dụng một kho mã nguồn GitHub trong suốt quá trình thực hiện các bài lab.** Các yêu cầu cụ thể như sau:

1. Mỗi bài lab phải được lưu trữ trong kho mã nguồn GitHub và được cập nhật sau khi hoàn thành.
2. Mã nguồn phải được tổ chức theo thư mục tương ứng với từng lab, có cấu trúc rõ ràng và nhất quán.
3. Mỗi thư mục lab phải kèm theo tệp **README.md** mô tả ngắn gọn mục tiêu, nội dung chính và hướng dẫn chạy chương trình (nếu có).
4. Kho mã nguồn phải chứa đầy đủ các phiên bản mã nguồn đã thực hiện trong học phần và duy trì ở trạng thái có thể truy cập được (public hoặc cấp quyền cho giảng viên) để phục vụ việc kiểm tra khi cần thiết.

Lưu ý

Việc đánh giá được thực hiện dựa trên các tiêu chí sau:

- Mức độ hoàn thành của từng nhiệm vụ theo yêu cầu đề bài.
- Tính đúng đắn của kết quả và phương pháp thực hiện.
- Chất lượng trình bày trong báo cáo (rõ ràng, logic, đầy đủ minh họa khi cần).
- Chất lượng mã nguồn (tổ chức, khả năng chạy lại, tính rõ ràng).
- Mức độ tuân thủ các quy định về nộp bài và quản lý mã nguồn.

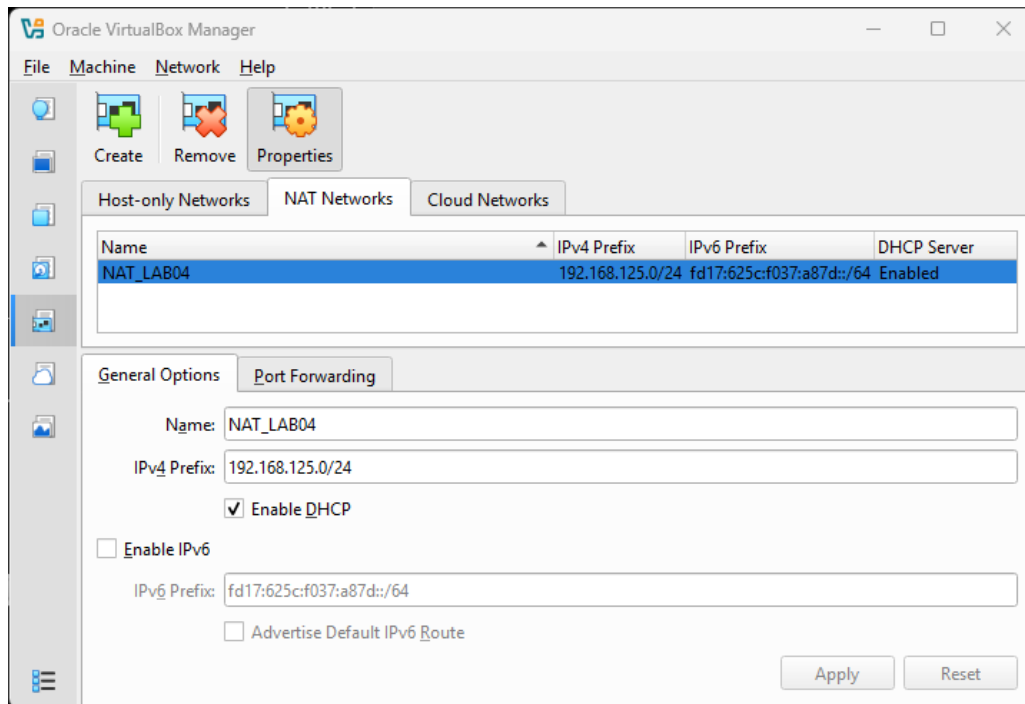
Đánh giá

Lưu ý: Không chia sẻ bất kỳ tài liệu nào của học phần (slide bài giảng, tài liệu đọc, bài tập, bài lab, v.v.) ra ngoài lớp học khi chưa có sự cho phép của giảng viên.

Chúc các bạn học tập tốt và đạt kết quả cao trong học phần!!!

A PHỤ LỤC CÀI ĐẶT

A.1 Cấu hình mô hình mạng



Hình 36: Cấu hình địa chỉ mạng 192.168.125.0/24 cho môi trường lab

A.1.1 Hướng dẫn Tạo mạng NAT 192.168.125.0/24 trên VMware

Bước 1: Mở Virtual Network Editor

1. Mở VMware Workstation
2. Vào Edit → Virtual Network Editor
3. Nhấn Change Settings (nếu yêu cầu quyền admin)

Bước 2: Tạo network mới

1. Nhấn Add Network
2. Chọn mạng trống, ví dụ: VMnet5
3. Nhấn OK

Bước 3: Cấu hình NAT cho VMnet5

Trong danh sách, chọn VMnet5:

1. Tick vào NAT (shared with host)
2. Tại phần Subnet IP: nhập 192.168.125.0
3. Subnet mask: 255.255.255.0

Bước 4: Cấu hình DHCP (nếu muốn cấp IP tự động)

1. Bấm DHCP Settings

2. Cấu hình:

- Start IP address: 192.168.125.100
- End IP address: 192.168.125.200
- Gateway: 192.168.125.2 (sinh viên cần kiểm tra kỹ)

Nhấn OK

Bước 5: Áp dụng mạng cho máy ảo

Vào cấu hình của VM → Network Adapter:

- Chọn Custom: VMnet5

Máy ảo sẽ nhận IP trong dải 192.168.125.0/24.

A.1.2 Hướng dẫn Tạo mạng NAT 192.168.125.0/24 trên Oracle VirtualBox

Bước 1: Mở Global Tools

1. Mở VirtualBox
2. Vào File → Tools → Network
3. Chọn tab NAT Networks
4. Nhấn Create để tạo NAT network mới

Bước 2: Cấu hình NAT Network

Bấm vào NAT network mới → chọn Properties:

Mục	Giá trị
Network Name	NAT-125 (tùy chọn)
Network CIDR	192.168.125.0/24
Supports DHCP	Bật
IPv6	Tắt (không cần)

→ Gateway tự động sẽ là: 192.168.125.1 (sinh viên cần kiểm tra lại)

Bước 3: Gán mạng cho máy ảo

Trong VM → Settings → Network:

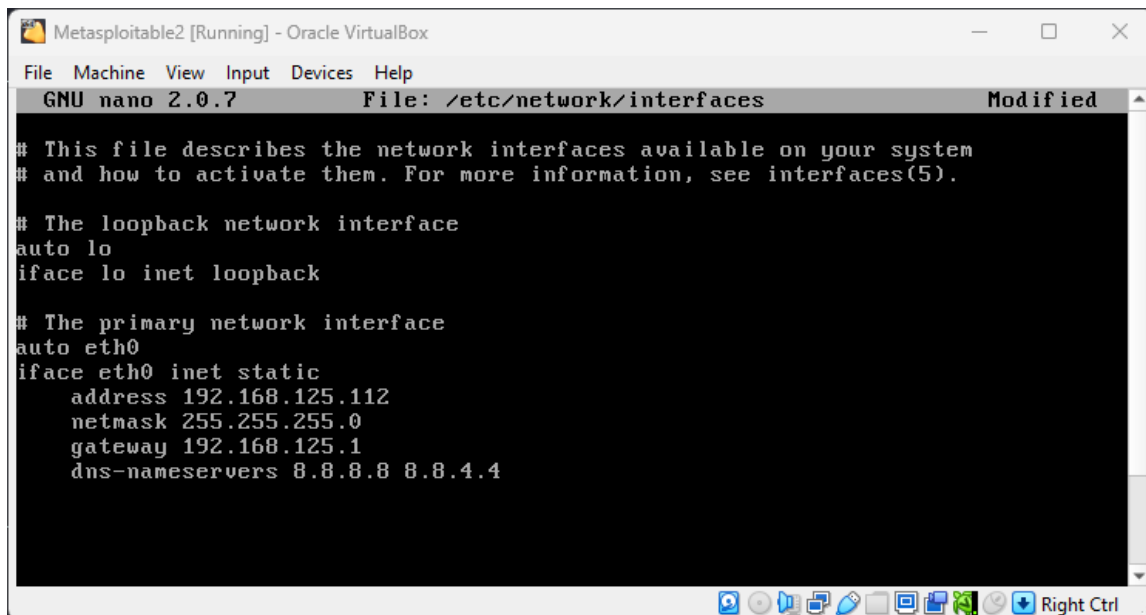
- Adapter 1 → Enable Network Adapter
- Attached to: NAT Network
- Name: NAT-125

A.2 Hướng dẫn cài đặt địa chỉ IP tĩnh

Có nhiều cách để cài đặt địa chỉ IP tĩnh cho máy Linux. Trong phạm vi bài lab này, sinh viên thực hiện theo phương pháp chỉnh sửa file cấu hình mạng truyền thống, áp dụng cho các hệ thống Linux cũ (ví dụ: Ubuntu Server 14.04, Metasploitable 2).

- **Bước 1:** Mở và chỉnh sửa file cấu hình mạng:

```
nano /etc/network/interfaces
```



Hình 37: Cấu hình địa chỉ IP tĩnh cho máy Metasploitable 2

- **Bước 2:** Cấu hình địa chỉ IP tĩnh cho interface (ví dụ: eth0) như sau:

```
auto eth0
iface eth0 inet static
    address 192.168.125.112
    netmask 255.255.255.0
    gateway 192.168.125.2
    dns-nameservers 8.8.8.8 8.8.4.4
```

Trong đó:

- address: địa chỉ IP tĩnh gán cho máy
- netmask: subnet mask của mạng
- gateway: địa chỉ IP của router, sinh viên kiểm tra lại địa chỉ của gateway trong card mạng ảo.
- dns-nameservers: máy chủ DNS

- **Bước 3:** Lưu file và thoát:

- Nhấn **Ctrl + O** để lưu
- Nhấn **Ctrl + X** để thoát

- **Bước 4:** Khởi động lại dịch vụ mạng:

```
sudo service networking restart
```

Hoặc:

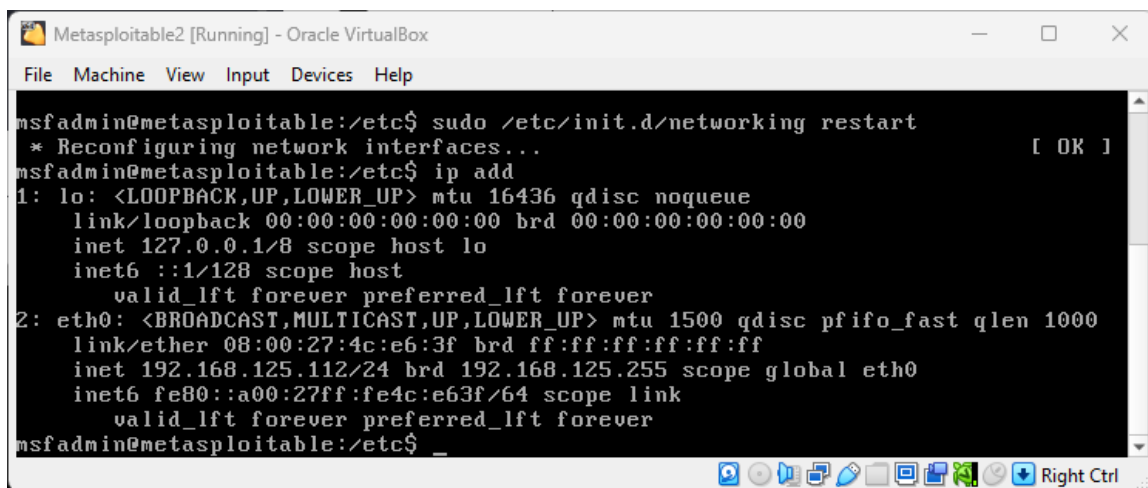
```
sudo /etc/init.d/networking restart
```

- **Bước 5:** Kiểm tra lại cấu hình:

```
ifconfig
```

hoặc:

```
ip addr show
```



Hình 38: Khởi động lại dịch vụ mạng và kiểm tra lại cấu hình

Lưu ý:

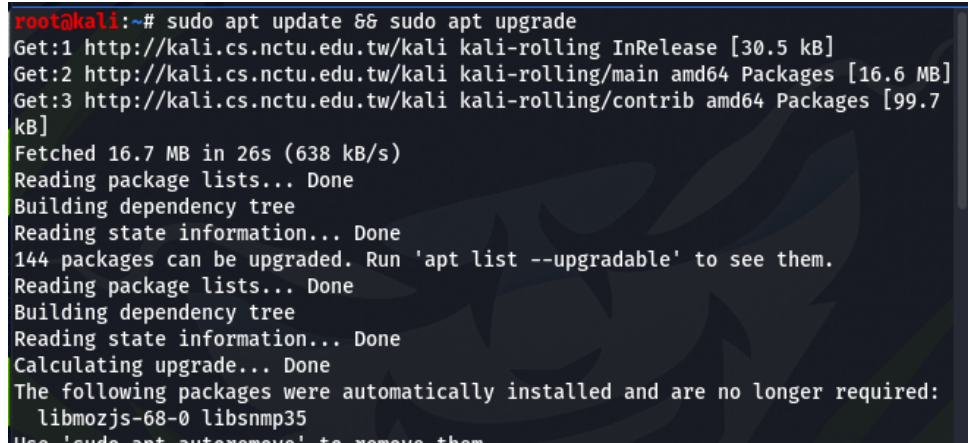
- Đảm bảo địa chỉ IP cấu hình cùng dải mạng với gateway.
- Không sử dụng địa chỉ IP đã được cấp phát cho thiết bị khác để tránh xung đột.
- Kiểm tra tên interface mạng (eth0, ens33,...) bằng lệnh `ip a`.

Sinh viên có thể thực hiện tương tự để cài đặt địa chỉ IP tĩnh trên máy Kali hoặc máy Ubuntu dùng để cài đặt Nessus.

A.3 Hướng dẫn cài đặt Nessus

Trước khi cài đặt, đảm bảo máy Kali Linux luôn ở phiên bản mới nhất bằng lệnh:

```
sudo apt update && sudo apt upgrade
```

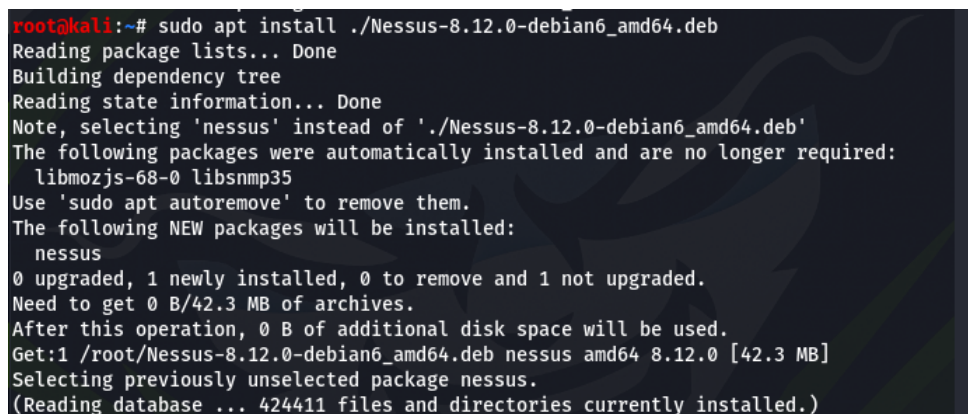


```
root@kali:~# sudo apt update && sudo apt upgrade
Get:1 http://kali.cs.nctu.edu.tw/kali kali-rolling InRelease [30.5 kB]
Get:2 http://kali.cs.nctu.edu.tw/kali kali-rolling/main amd64 Packages [16.6 MB]
Get:3 http://kali.cs.nctu.edu.tw/kali kali-rolling/contrib amd64 Packages [99.7
kB]
Fetched 16.7 MB in 26s (638 kB/s)
Reading package lists... Done
Building dependency tree
Reading state information... Done
144 packages can be upgraded. Run 'apt list --upgradable' to see them.
Reading package lists... Done
Building dependency tree
Reading state information... Done
Calculating upgrade... Done
The following packages were automatically installed and are no longer required:
  libmozjs-68-0 libsnmp35
Use 'sudo apt autoremove' to remove them.
```

Hình 39: Đảm bảo máy Kali Linux được cập nhật phần mềm mới nhất

Mặc dù Nessus không có trong repository của Kali, chúng ta có thể tải về tập tin 64-bit .deb tại trang chủ của Tenable: <https://www.tenable.com/downloads/nessus>. Chúng ta có thể kiểm tra giá trị checksum MD5 hoặc SHA256 bằng cách bấm vào liên kết “Checksum”. Sau khi tải về, kiểm tra tính toàn vẹn của tập tin bằng lệnh md5sum (đối với giá trị MD5) hoặc sha256sum (đối với giá trị SHA256), đảm bảo giá trị của tập tin này trùng khớp với giá trị được công bố trên trang chủ.

Sau khi **đảm bảo tính toàn vẹn được bảo toàn trong quá trình tải tập tin cài đặt về máy**, thực hiện cài đặt bằng lệnh apt:



```
root@kali:~# sudo apt install ./Nessus-8.12.0-debian6_amd64.deb
Reading package lists... Done
Building dependency tree
Reading state information... Done
Note, selecting 'nessus' instead of './Nessus-8.12.0-debian6_amd64.deb'
The following packages were automatically installed and are no longer required:
  libmozjs-68-0 libsnmp35
Use 'sudo apt autoremove' to remove them.
The following NEW packages will be installed:
  nessus
0 upgraded, 1 newly installed, 0 to remove and 1 not upgraded.
Need to get 0 B/42.3 MB of archives.
After this operation, 0 B of additional disk space will be used.
Get:1 /root/Nessus-8.12.0-debian6_amd64.deb nessus amd64 8.12.0 [42.3 MB]
Selecting previously unselected package nessus.
(Reading database ... 424411 files and directories currently installed.)
```

Hình 40: Cài đặt Nessus

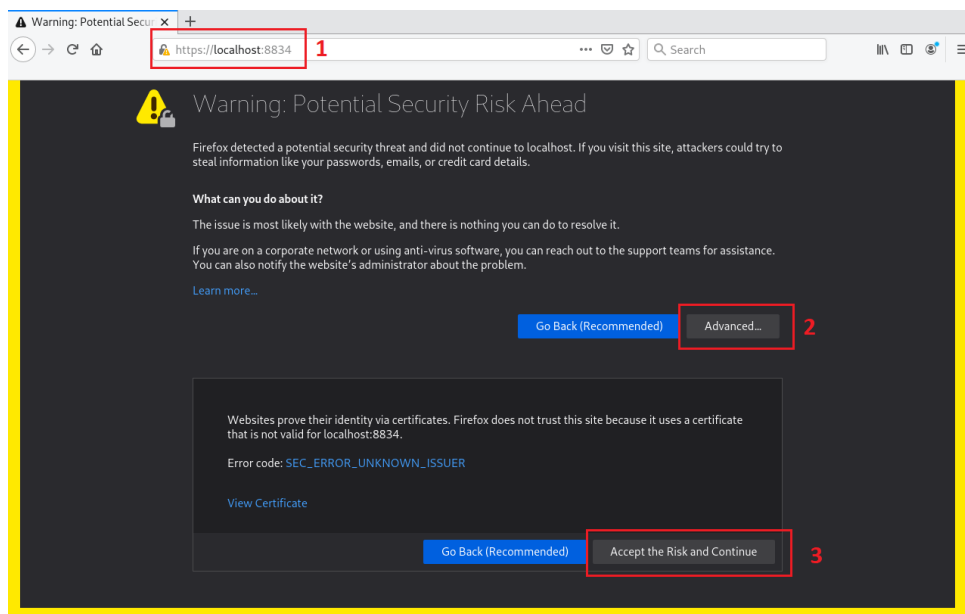
Sau khi cài đặt thành công, thực hiện khởi động dịch vụ nessusd.

```
root@kali:~# /bin/systemctl start nessusd.service
root@kali:~# systemctl status nessusd
● nessusd.service - The Nessus Vulnerability Scanner
   Loaded: loaded (/lib/systemd/system/nessusd.service; disabled; vendor preset: >
   Active: active (running) since Sun 2020-10-11 08:25:20 EDT; 18s ago
     Main PID: 18102 (nessus-service)
        Tasks: 12 (limit: 4602)
       Memory: 133.7M
          CGroup: /system.slice/nessusd.service
                 └─18102 /opt/nessus/sbin/nessus-service -q
                   └─18103 nessusd -q

Oct 11 08:25:20 kali systemd[1]: Started The Nessus Vulnerability Scanner.
lines 1-11/11 (END)
```

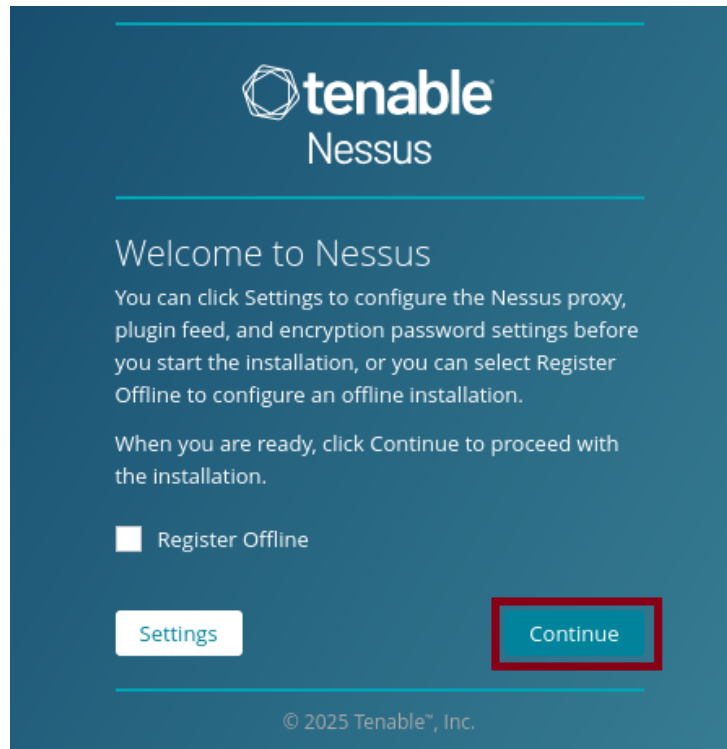
Hình 41: Khởi động dịch vụ nessusd

Sau khi khởi động Nessus, mở trình duyệt và truy cập vào đường dẫn <https://localhost:8834/>. Chúng ta sẽ được thông báo lỗi certificate, chọn Advanced... → Accept the Risk and Continue.



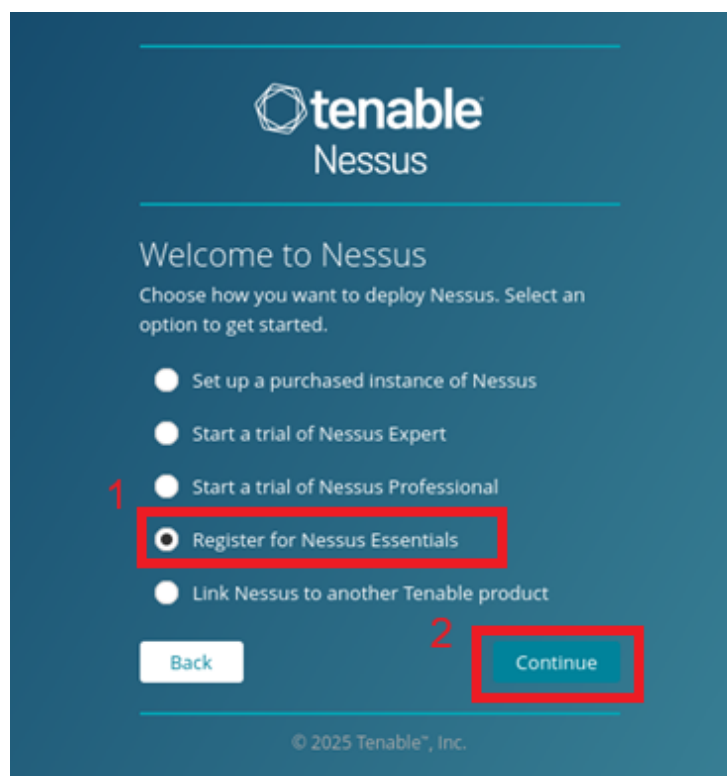
Hình 42: Bỏ qua lỗi certificate

Sau khi đợi trang được tải lên, Nessus hiển thị thông báo Welcome to Nessus..., chúng ta chọn **Continue** để có thể đăng ký và sử dụng Nessus ngoại tuyến.



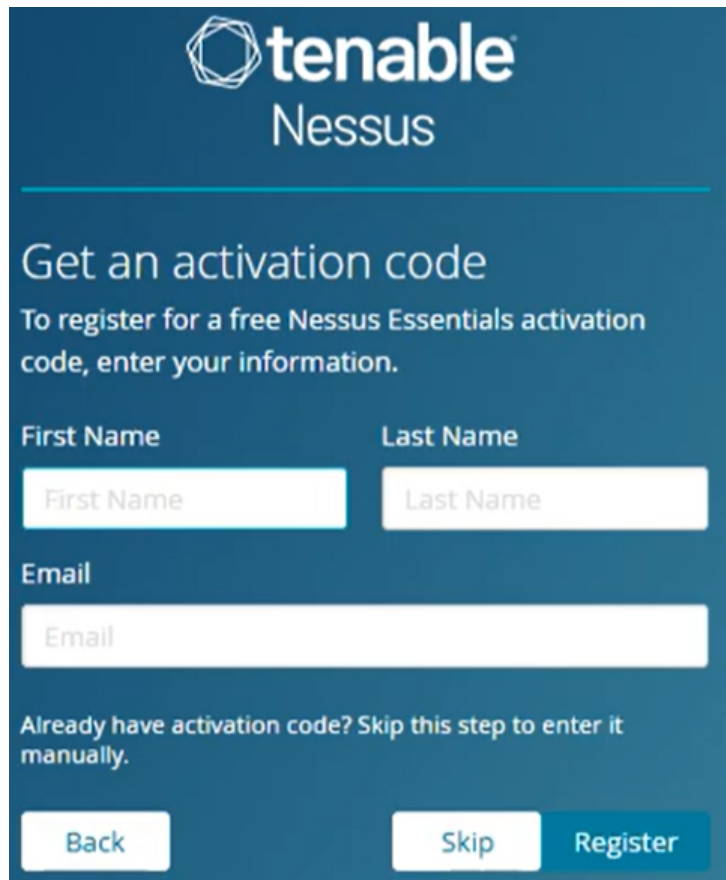
Hình 43: Không chọn gì khác, trực tiếp click chọn **Continue**

Tiếp theo, chúng ta được thông báo chọn phiên bản Nessus muốn sử dụng. Trong trường hợp này, chọn Nessus Essentials, sau đó chọn Continue

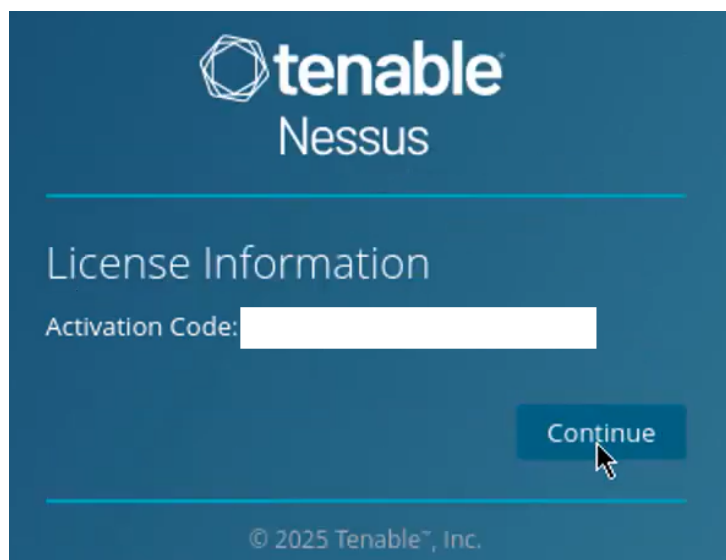


Hình 44: Chọn cách dựng Nessus: Chọn **Register for Nessus Essentials**

Tiếp theo, nhập các thông tin theo yêu cầu (đề xuất chỉ cần nhập đúng format).

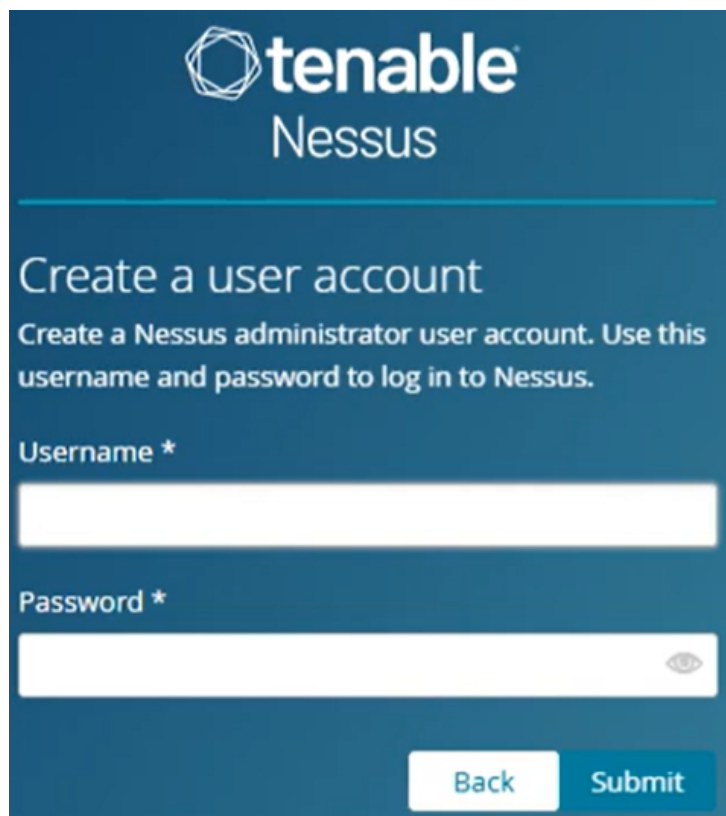


Hình 45: Nhập thông tin theo yêu cầu



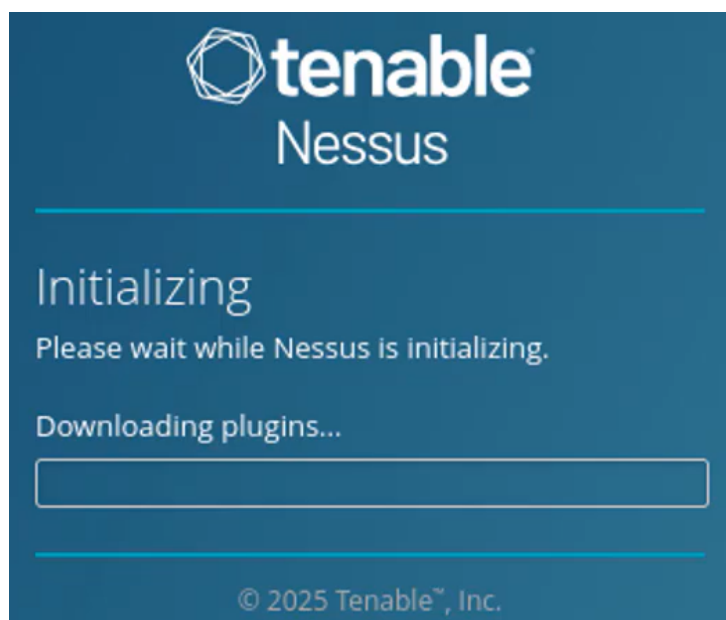
Hình 46: Đăng ký thành công, Nessus hiển thị License Information

Bây giờ, Nessus đã được kích hoạt, công việc tiếp theo sẽ là tạo tài khoản quản trị Nessus. Nhập tên username, password và sau đó nhấn Submit



Hình 47: Tạo tài khoản quản trị Nessus

Cuối cùng, chờ quá trình cập nhật và cài đặt các plugin hoàn tất. Quá trình này sẽ mất khá nhiều thời gian.



Hình 48: Chờ cập nhật Nessus